



LEGAL AND SOCIAL ISSUES IN PRIVACY AND SECURITY



SECURITY AND PRIVACY, LEGAL ISSUES

- Rapid developments of computer systems, networks give rise for
 - New threats for security and privacy
 - New defensive measures
- We have seen various technical means to protect security and privacy in computer systems and networks
- In real life they should be accompanied by law regulations.

INTERNATIONAL AND NATIONAL POLITICS ISSUES

- US Export control on cryptographic software:
 - was the main reason to separate JCA and JCE in Java cryptographic library implementation
- Discussions in British Parliament:
 - the government proposal on 90 (...42...28) days detention was motivated in a part by necessity to have more time for decryption of intercepted correspondence

LEGAL RESTRICTIONS ON CRYPTOGRAPHY

- The legal landscape of cryptography is complex and constantly changing.
- Many aspects:
 - Cryptography and patent system
 - Cryptography and Trade secret Law
 - National and International regulations of cryptography
 - Digital Rights management



CRYPTOGRAPHY AND PATENT SYSTEM

- Early development of cryptographic protocols and systems was influenced by patent law
- Many important techniques, including *public key cryptography* have been patented, including:
 - Diffie-Hellman key exchange algorithm (expired 1997)
 - RSA encryption algorithm (expired 2000)
- In general, one of the results of the patent protection appeared to be reduced use of the invention



CRYPTOGRAPHY AND TRADE SECRET LAW

- Until recently many encryption algorithms were kept as proprietary, secret and protected by the trade secret provisions
- The idea was that one could achieve *additional security for the encrypted data by keeping the encryption algorithms themselves secret*
- Most experts does not support such idea:
 - It is almost impossible to keep the details of successful algorithm secret
 - If the algorithm has a hidden flaw, then it is could be discovered too late: e.g.: Content Scramble System (CSS) algorithm for protecting DVD content
- There are still many patented algorithms, and they are protected by law

LEGAL REGULATIONS OF CRYPTOGRAPHY

Motivations (at national level):

- Cryptography can be used to hide criminal activities
- Strong cryptography can make difficult, or almost impossible to conduct search warrants by legal authorities

Motivations (at international level):

- Strong cryptography can make impossible to decrypt correspondence by military, economic, etc, competitors, or in general, unfriendly countries.

US REGULATORY EFFORTS

Special costly, time consuming licenses for export machines or programs implementing cryptography

1980s

Proposals by US administration to use key escrow techniques: Clipper chip and software key escrow

1992–1996

1992

Free export of cryptographic programs, but with the restriction on key size: no more than 40 bits

CLIPPER CHIP

Escrowed Encryption Standard (Clipper Chip)

A cheap tamper-proof chip, each with unique ID

A classified encryption algorithm

A back door is embedded, and the government has a copy of a key used in every such a chip. So, when authorized, all encrypted message can be decrypted

Mechanisms to ensure security of keys and no unauthorized use of the “back door”

1997: Leading cryptographers and computer scientists published a report:
“... government encryption plan is risky and impractical”

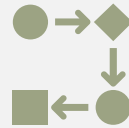
POTENTIAL PROBLEMS WITH CLIPPER CHIP



The potential for
insider abuse



The creation of new
vulnerabilities and
targets for attack



Scaling



The difficulties
of properly
authenticating
requests for keys



The cost

US REGULATIONS

January 2000, new regulations:

- Allowed export of cryptographic products with *any key* length after a technical review to any country that was not specifically listed a terrorist country
- Essentially, export control on strong cryptography was eliminated

INTERNATIONAL AGREEMENTS ON CRYPTOGRAPHY

[Wassenaar Arrangement](#) on Export Control for Conventional Arms and Dual-Use Goods and Technologies

- 1996 – Present
- Allows export of mass-market software
- Allows export of all products that use encryption to protect intellectual property



DIGITAL RIGHTS MANAGEMENT

Digital Millennium Copyright Act (US, 1998):

- Criminalizes production and dissemination of technology for circumventing the control access for the copyrighted works
- Controversy: Dmitry Sklyarov case (2001)
- Copyright protection vs legality of cryptanalytic research?

Copyright Directive (EU 2001)



INTERNATIONAL AGREEMENTS ON CRYPTOGRAPHY

- **Council of Europe Recommendation 95 (13), 1995 - Present**
 - recommendations on use of cryptography
- **European Union Council Regulation 1334/2000:**
 - export to other EU countries unrestricted
 - export to other countries may require an authorization, or license



PRIVACY PROTECTION: OECD GUIDELINES

- In 1980, the Organization for Economic Co-operation Development and (OECD) adopted a set of privacy guidelines
- **Aim:** to harmonize the growing number of privacy regulations throughout the industrialized world
- The guidelines were specifically designed to deal with growing problem of *transborder data flows*
- The guidelines consist of eight main principles.

OECD GUIDELINES: MAIN PRINCIPLES



Collection Limitation Principle: there should be limits to the collection of personal data, and any such data should be obtained by lawful and fair means



Data Quality Principle: personal data should be relevant to the purposes for which it is to be used, should be accurate, complete, and kept up to date.

Purpose Specification Principle: the purposes for which personal data is collected should be specified not later than at the time of data collection and the subsequent use limited to the fulfilment of those purposes

Use Limitation Principle: Personal data should not be disclosed, made available, or otherwise used for purposes others than those specified in advance, except:

- With the consent of the data subject, or
- By authority of law

OECD
GUIDELINES:
MAIN
PRINCIPLES

OECD GUIDELINES: MAIN PRINCIPLES



Security Safeguards Principle: personal data should be protected by reasonable security safeguards against such risks as loss, unauthorized access, destruction, etc.



Openness Principle: there should be a general policy of openness about developments, practices and policies with respect to personal data.

OECD GUIDELINES: MAIN PRINCIPLES

Individual Participation Principle: an individual should have the right

- To obtain the data from a data controller, or confirmation of whether the data controller has data relating to them
- To be given reasons if a request made specified as above is denied, and to be able to challenge such denial, and
- To challenge data relating to them and, if the challenge is successful to have the data erased, rectified, completed, or amended.



OECD GUIDELINES: MAIN PRINCIPLES

Accountability principle: a data controller should be accountable for complying with measures which give effect to the principle stated above.

The OECD Guidelines do not have the force of law, but are instead used as guidelines for each OECD member country (30 countries at the moment, including UK) when passing its own laws



EUROPEAN DATA PROTECTION

Was: European Union Directive 95/46/EC, the *Directive* on Protection of Personal Data



New: General Data Protection *Regulation* (GDPR) (from 25 May 2018)

UK DATA PROTECTION ACT

- The Data Protection Act 2018 is the UK's implementation of the General Data Protection Regulation (GDPR).

Data protection act 2018: <https://www.gov.uk/data-protection>

- Have a look at the above link and compare these regulations with OECD guidelines.

